

CLAUDE DESIGN AUTHORITY

K8s Event Triage Platform

AI-powered triage for Kubernetes · `kagent-triage`

OWNER	VERSION	DATE	STATUS
Platform Engineering	1.0 — Draft	2026-03-31	Pending Review

AGENDA

What we'll cover today

01

Summary

What · Why · Who · Where

02

Threat Scenarios

11 risks · controls · residual

03

Black Box View

Boundaries · data flows

04

White Box View

Functional layers

05

RBAC Model

Least privilege end-to-end

06

Decision Requested

Approve rollout

SECTION 01

Summary

What, why, who, where — at a glance

WHAT IS IT?

AI triage for Kubernetes events

An **AI-powered platform** that automatically detects, diagnoses, and reports on Kubernetes warning events across multiple AKS worker clusters — using namespace-scoped agents built on **kagent (CNCF Sandbox)**.



Detect

Warning events across all AKS workers, in real time



Diagnose

LLM root-cause analysis, namespace-scoped agents



Report

GitLab issues · Teams notifications

Runs on a management cluster orchestrating triage across remote workers via workload identity and AKS-MCP.

WHY NOW?

The numbers that matter

INVESTIGATION TIME

~60s ▼ from 30–60 min

Automated vs manual triage

MTTD IMPACT

Event-level

Catches issues before P1/P2

SCALE COST

1 agent

Per namespace · no extra headcount

OUTPUT QUALITY

Standard

Severity · RCA · remediation

STAKEHOLDERS

Who's involved

ROLE	TEAM	RESPONSIBILITY
Platform Engineer (Owner)	Platform Engineering	Design, deploy, operate
Security Reviewer	InfoSec	Approve threat model, RBAC
Data Governance	Data Office	Approve data flows, LLM privacy
Service Owner	Platform Engineering	Day-to-day operations
Consumers	SRE / Operations	Receive triage output

DEPLOYMENT TOPOLOGY

Where it runs

ENVIRONMENT	CLUSTER / SERVICE	PURPOSE
Management plane	AKS management cluster	kagent · Argo Events/Workflows · LiteLLM
Worker clusters	AKS worker clusters (N)	Event source + diagnostic reads
Event transport	Azure Event Hub (Standard)	Cross-cluster event bus
Output: issues	GitLab	Persistent triage record
Output: notifis	Microsoft Teams (Logic App)	Real-time channel
AI inference	Azure OpenAI / on-prem LLM	Diagnostic generation

IMPACT IF BLOCKED

What happens if we don't ship

- P1/P2 escalations continue — warning events remain invisible until incidents
- Reactive firefighting without structured diagnostic data
- Triage quality varies by who's on-call and their platform knowledge
- 30–60 minute investigations remain the norm (vs. ~60s automated)
- Manual namespace onboarding stays error-prone and doesn't scale

DEPENDENCY MAP

What we depend on

COMPONENT	ROLE	IMPACT IF DOWN
kagent (v0.8.0+)	Core — agent framework	No triage
Argo Workflows (v3.6.4+)	Core — orchestration	No triage
Argo Events (v1.9+)	Core — event routing	Events not consumed
Azure Event Hub	Transport	Mgmt blind; local triage OK
LiteLLM / LLM	Core — AI inference	Degrades — raw GitLab issue
GitLab API	Output — issue store	Teams still fires
Logic App (Teams)	Output — notifications	GitLab still works
External Secrets Operator	Support — rotation	Manual rotation

SECTION 02

Threat Scenarios

11 risk categories · all residual Low or Very Low

OVERVIEW

The assessment approach



Threat

What could go wrong — concrete actor + action



Controls

Preventive · detective · corrective mechanisms



Residual

What's left after controls are applied

All **11 scenarios** assessed against the CDA risk taxonomy. Result: **Low or Very Low** residual risk across the board.

2.1 · INTERNAL DATA THEFT

A platform admin exfiltrates triage data

RESIDUAL · LOW

CONTROLS

- RBAC: only `platform-team-admins` AD group
- Kyverno denies non-platform kagent CRD ops
- Azure AD + K8s audit logs → SIEM

WHY LOW

Data is operational metadata — pod names, event reasons, namespaces. No secrets, no PII. Same data visible via `kubect1 get events`.

2.2 · EXTERNAL DATA THEFT

An attacker breaches external exposure

RESIDUAL · VERY LOW

CONTROLS

- Zero external ingress — all ClusterIP
- Event Hub SAS (Send-only / Listen-only split)
- NetworkPolicy default-deny on kagent, argo-events
- Outbound: HTTPS + token auth only

WHY VERY LOW

No external attack surface exists. Only external paths are Event Hub (SAS + TLS 1.2+) and outbound HTTPS with tokens.

2.3 · ACCESS TO RESTRICTED DATA

Agent reaches beyond its assigned scope

RESIDUAL · LOW

LAYERED CONTROLS

- Triage agents **read-only by default** (get, list, watch)
- Namespace-scoped **Role** not ClusterRole
- Agent prompt: **CRITICAL: always use exact namespace "X"**
- AKS-MCP UAMI scoped to **specific clusters** — not subscription-wide
- Remediation requires explicit **remediate=true** parameter

RBAC is the hard boundary. Prompt constraints are defence-in-depth, not the primary control.

2.4 · ENFORCED EXPOSURE OF DATA

Prompt injection forces LLM to leak

RESIDUAL · LOW

ATTACK SURFACE

Narrow — only K8s event message field is user-influenceable. Events carry standard K8s fields, no free-text.

MITIGATIONS

- LLM output truncated to 4000 chars
- Prompts: never output secret values
- Destinations: authenticated internal channels only
- LiteLLM logs all prompts/completions

2.5 – 2.7 · DATA LIFECYCLE

Privacy · retention · disposal

#	THREAT	RESIDUAL
2.5	Unlawful data processing	VERY LOW — No PII, ops metadata only. Azure OpenAI DPA in place.
2.6	Retention not compliant	LOW — Argo 30d · Loki 30d hot/90d cold · GitLab indefinite · dedup 24h TTL
2.7	Inadequate disposal	LOW — Automated TTL · Azure OpenAI 30d abuse log only · no on-prem persistence

2.8 · EXTERNAL DENIAL OF SERVICE

An attacker overwhelms the pipeline

RESIDUAL · LOW

3-LAYER DEDUPLICATION

1 · Alloy

Drop `count>1` events · 10/s rate limit

2 · Sensor

Rate limit 5/min per sensor

3 · Script

24h TTL keyed dedup in ConfigMap

Plus: LiteLLM `max_parallel_requests`, Argo `activeDeadlineSeconds: 900`, Event Hub throttling.

2.9 – 2.11 · AUDIT, INTERNAL DOS, EXPOSURE

Remaining scenarios

#	THREAT	KEY CONTROL	RISK
2.9	Can't fulfil info requests	Overlapping audit: Argo 30d · KAgent logs · LiteLLM logs · GitLab permanent	LOW
2.10	Internal user disrupts pipeline	RBAC + Kyverno + GitOps PR review	LOW
2.11	Accidental exposure	GitLab ACL · Teams webhook as Secret · detect-secrets CI	LOW

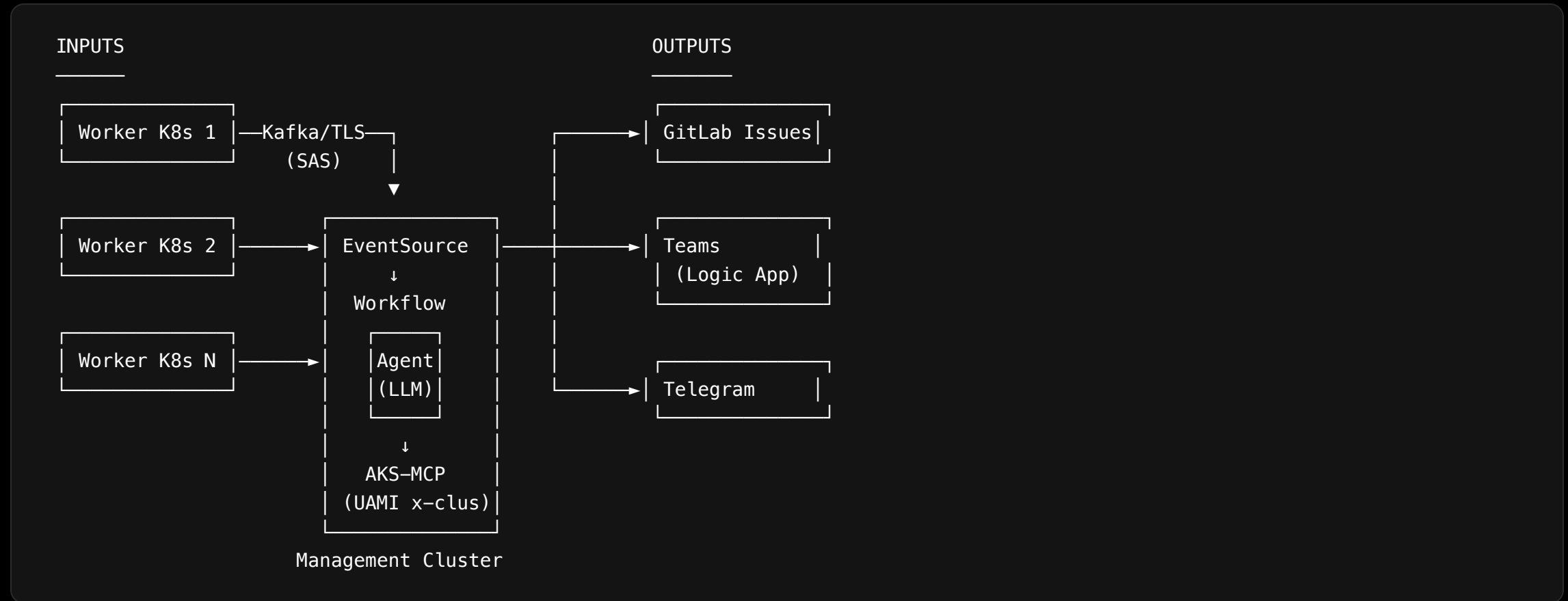
SECTION 03

Black Box View

Boundaries · data flows · actors

SYSTEM BOUNDARY

What goes in, what comes out



DATA FLOWS 1 - 5

Ingress, orchestration, inference

#	FROM	TO	DATA	AUTH
1	Worker (Alloy)	Event Hub	K8s warning metadata	SAS (Send)
2	Event Hub	EventSource	K8s warning metadata	SAS (Listen)
3	Sensor	Argo Workflow	Filtered event payload	In-cluster SA
4	Workflow	KAgent	A2A JSON-RPC + event	In-cluster network
5	KAgent	LiteLLM	Prompt (event + system)	API key

DATA FLOWS 6 - 10

Diagnosis reads & outputs

#	FROM	TO	DATA	AUTH
6	LiteLLM	LLM provider	Prompt	HTTPS + API key
7	KAgent (AKS-MCP)	Worker K8s API	kubectl get/describe/logs	UAMI · workload identity
8	Workflow	GitLab	Issue (title/desc/labels)	PAT (api, 1 project)
9	Workflow	Logic App	Triage JSON	Webhook SAS
10	Workflow	Telegram	Notification text	Bot token

WHO ACCESSES THE SYSTEM?

Five actors, five access patterns

ACTOR	METHOD	ACCESSES	WHY
Platform Engineers	kubectl + Azure AD	kagent · argo-events · argo namespaces	Operate pipeline
AI Agents (kagent)	A2A in-cluster	KAgent · LiteLLM · worker K8s API	Diagnose events
Argo Workflows	K8s service account	Workflow exec · secret read	Orchestrate triage
Alloy (workers)	Kafka/TLS	Event Hub (write-only)	Forward events
SRE / Ops	GitLab UI · Teams	Triage issues + notifs	Act on output

SECTION 04

White Box View

Functional layers · service composition

FUNCTIONAL LAYERS

A 4-tier architecture

USER	GitLab UI Teams Grafana Dashboards
ACCESS	Azure AD · Event Hub SAS · K8s SA Kyverno · NetworkPolicy · Workload ID
SERVICE	Argo Events · Argo Workflows · kagent Ctrl LiteLLM · AKS-MCP · Notification Services
RESOURCE	Event Hub · etcd · LLM Provider Key Vault · Loki · GitLab
HORIZONTAL	Logging · Monitoring · Secrets · GitOps Audit Trail · Dedup · Pod Cleanup

SERVICE LAYER

The pipeline, piece by piece

- Argo Events — EventSource, Sensors (ns-filtered, rate-limited), EventBus (NATS)
- Argo Workflows — `kagent-triage` DAG: find → diagnose → notify
- kagent Controller — Agent CRDs, A2A endpoint, namespace-scoped tool server, ModelConfig routing
- LiteLLM — Gateway · rate limiting · token tracking · Prometheus metrics
- AKS-MCP — UAMI-backed cross-cluster kubectl (read-only by default)
- Notification Services — GitLab · Logic App · Telegram

ACCESS LAYER

Defence in depth — 6 mechanisms

CONTROL	PURPOSE
Azure AD RBAC	Human access (platform-team-admins only)
Event Hub SAS	Per-direction least privilege — Send ≠ Listen
K8s Service Accounts	Workflow and agent identity
Kyverno Admission	CRD restriction — belt-and-braces enforcement
NetworkPolicy	Default-deny on kagent / argo-events namespaces
Workload Identity	Cross-cluster via FIC · per-cluster scope

HORIZONTAL FUNCTIONS

Cross-cutting concerns

LOGGING

All → Loki · 30d hot · 90d cold

MONITORING

Prometheus + PrometheusRules (LLM errors, token anomalies)

SECRET MGMT

ESO ← Azure Key Vault · 1h refresh

GITOPS

All manifests in Git · PR review required

DEDUPLICATION

3-layer: Alloy · Sensor · Script 24h TTL

AUDIT TRAIL

Argo history · KAgent logs · LiteLLM · GitLab

SECTION 05

RBAC Model

Least privilege at every layer

MANAGEMENT CLUSTER — HUMANS

Who can do what

ROLE	IDENTITY	SCOPE	PERMISSIONS
Platform Admin	AD: <code>platform-team-admins</code>	kagent · argo-events · argo ns	<code>admin</code> ClusterRole
Platform Admin	AD: <code>platform-team-admins</code>	Cluster-wide (kagent CRDs)	<code>kagent-admin</code> all verbs
Non-platform	Any other AD user	kagent · argo-events	<code>DENIED</code> by Kyverno

Kyverno is the belt-and-braces — denies access even if RBAC is misconfigured.

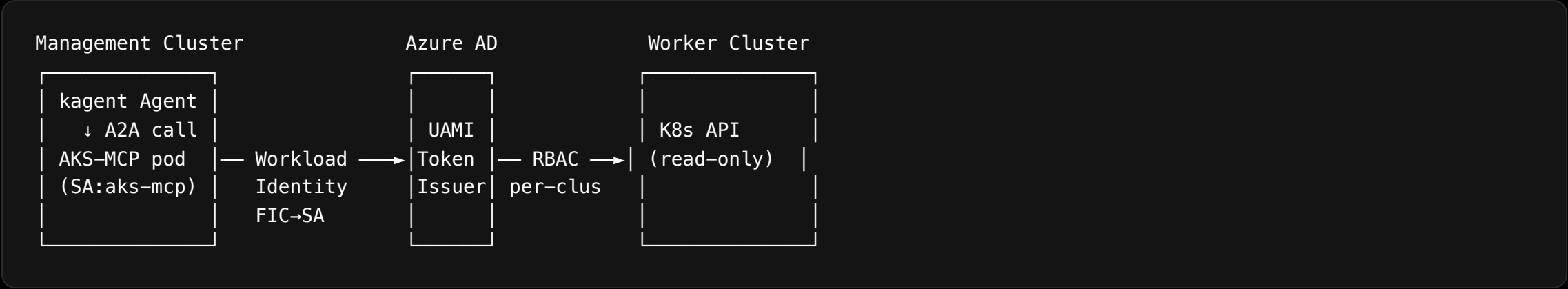
Machine identities

SA	NAMESPACE	VERBS	PURPOSE
argo-events-sa	argo-events	workflows: create/get/list/watch	Sensors trigger workflows
argo-events-sa	cluster	pods · logs · events: read	Diagnostics
argo-events-sa	cluster	configmaps: create/update	Dedup cache
aks-mcp	aks-mcp	all (local)	Self-diagnostics

Worker clusters: kagent tool-server SA is **read-only** (pods, logs, events, deployments, services).

CROSS-CLUSTER ACCESS

Workload Identity → Azure RBAC → Worker



COMPONENT DETAIL

Identity	Azure User Assigned Managed Identity (UAMI)
Binding	Federated Identity Credential → aks-mcp SA in aks-mcp ns
Scope	Per-cluster — not subscription-wide
Ops	Read-only default · writes require remediate=true

WHY WORKLOAD IDENTITY?

Three concrete wins



No static creds

Tokens short-lived, auto-rotated by Azure AD



Azure-enforced

Compromised pod can only reach assigned clusters



Full audit

Azure AD sign-ins + K8s audit logs

Verify scope: `az role assignment list --assignee <UAMI_CLIENT_ID>`

AGENT-LEVEL RBAC

K8s RBAC + prompt constraints

AGENT TYPE	K8S RBAC	PROMPT CONSTRAINTS	TOOLS
Triage (default)	Read-only	CRITICAL: use namespace "X" · never fetch secrets	get_pods · get_events · describe · get_logs
Remediation	Read + limited write	Explicit remediate=true · never delete CRDs · never restart all replicas	Above + patch · scale

RBAC is the boundary · prompts are supplementary.

SECTION 06

Decision Requested

Approve `kagent-triage` for production rollout

NEXT STEPS

If approved today

01

Engineering rollout

Namespace-by-namespace deployment
starting April 2026

02

Worker bundle

Deploy local kagent + sensors to worker
clusters

03

SRE handoff

Runbooks + on-call training + ownership
transfer

SUPPORTING DOCUMENTS

Where to find the detail

DOCUMENT	LOCATION
STRIDE Threat Model	<code>docs/SAD-THREAT-MODEL.md</code>
Compliance Checklist	<code>docs/SAD-COMPLIANCE-CHECKLIST.md</code>
Logging · Monitoring · Auth	<code>docs/SAD-LOGGING-MONITORING-AUTH.md</code>
LLM Governance	<code>docs/SAD-LOGGING-MONITORING-LLM.md</code>
Secret Rotation Runbook	<code>docs/SECRET-ROTATION-RUNBOOK.md</code>
Shared Cluster RBAC	<code>docs/SHARED-CLUSTER-RBAC.md</code>
Worker Cluster Bundle	<code>worker-cluster-bundle/README.md</code>

THANK YOU

Questions?

Platform Engineering Team

Contact via `platform-team-admins` AD group